

Project Part 3 – Security, IAM & Monitoring

1. Requirements

Extend the solutions developed in Project Part 1 (Cloud-Deployed Application) and Project Part 2 (ETL Pipeline + Serverless Function) by adding basic security mechanisms and monitoring. The goal is to deliver a secure and observable cloud-native system.

1.1 Functional Requirements

- Secure the frontend and backend of the web application (Project Part 1) using a cloud identity provider (IdP):
 - Frontend: implement login and display the authenticated user's role (admin/user) from the JWT claims.
 - Backend: require a valid JWT for */api/data*, and create a new */api/profile* endpoint that returns the role claim.
 - Configure the IdP to issue a claim with *device_id* to restrict a user's access to specific device data.
- Protect the ETL pipeline and serverless function (Project Part 2):
 - Ensure that Blob/S3/GCS storage is private (no public access).
 - Allow access only through the ETL service, serverless function, and backend API via IAM roles/policies.
- Store credentials in secure environment variables or secret services.
- Enable basic monitoring/logging.
- Demonstrate role separation (e.g., admin vs user).

1.2 Implementation Technologies

- Identity & Auth (choose one provider):

- Azure: Entra ID (App registrations + App Roles), MSAL.js for SPA, App Service Authentication (“Easy Auth”).
- AWS: Amazon Cognito (User Pools/Hosted UI) + react oidc context Auth in the frontend.
- GCP: Identity Platform (Firebase Auth) with custom claims for device_id / allowed_devices.
- Secret Services: Azure KeyVault, AWS Secrets Manager, GCP Secrets Manager
- Monitoring/Logging: Azure Monitor (Insights free tier), AWS CloudWatch, GCP Cloud Logging

1.3 Non-Functional Requirements

- Logs should include security/authentication events where possible.
- Focus on using free-tier resources to minimize cost.

2. Deliverables

- Solution description document containing:
 - a) Integrated architecture (app + ETL + function + security + monitoring).
 - b) UML Deployment diagram including security and monitoring layers.
 - c) README file with build, deployment, and test instructions.
- In the Project Part 1 and Project Part 2 repositories, create a branch named **a3-secured**, implement the changes, and open a PR to **main** (or develop).

3. Evaluation

3.1 Project Related Basic Questions

During evaluation you may be asked about:

- IAM basics (users, roles, policies)
- Authentication/authorization principles
- Data encryption (at rest and in transit)
- Secrets management (env variables, secret stores)
- Logging and monitoring basics
- Role separation (admin vs user)

3.2 Grading

Points	Requirements
5 p	Minimum to pass: secure app + pipeline + function.
2 p	Role separation implemented (admin vs user), JWT device claim configured, role/claims visible in <i>/api/profile</i> , and server-side filtering by <i>device_id</i> verified.
1 p	Secrets stored securely (env variables or secret manager).
1 p	Monitoring/logging visible (logs in console or simple dashboard).
1 p	Documentation and repo structure (architecture diagram, setup steps, organized code).

Total: 10 points

Bonus (+1 p): If deployment is automated with Infrastructure-as-Code (Terraform, Pulumi, or AWS CDK), including setup of IAM roles, secrets, and monitoring in the free tier.

4. Bibliography

1. Microsoft Learn – [Azure Identity and Access Management](#)
2. AWS Docs – [AWS IAM Best Practices](#)
3. Google Cloud – [Cloud IAM Overview](#)
4. Microsoft Learn – [Azure Monitor Free Tier](#)
5. AWS Docs – [CloudWatch Logs](#)
6. Google Cloud – [Cloud Logging](#)